

[doc. web n. 9999973]
Provision of February 22, 2024
Register of provisions
n. 103 of February 22, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia, and Attorney Guido Scorza, members, and
Secretary General Fabio Mattei;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter, "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter
"Code");

HAVING REGARD TO Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers entrusted to the Guarantor for the
protection of personal data, approved by
resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc.
web n. 9107633 (hereinafter "Guarantor Regulation
No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary
General pursuant to Article 15 of the Guarantor's
Regulation No. 1/2000 on the organization and
operation of the office of the Guarantor for the
protection of personal data, doc. web n. 1098801;

REPORTING Prof. Ginevra Cerrina Feroni;

PREAMBLE

1. Introduction

With a complaint submitted on XX pursuant to Article
77 of the Regulation, against the Municipality of
Civita Castellana (hereinafter the "Municipality") and S.A.T.E. S.p.a.
(Environment Territory Energy Services, hereinafter the "Company"), Mr. XX, Mr. XX, and
Mr. XX reported that they had received a

communication, pursuant to Article 34 of the Regulation, in which the Municipality informed the interested parties of having become aware, through the Company, – as the manager of the waste collection service – “of the possibility of an illegitimate dissemination, through social media, of particular personal data belonging to some citizens [...] in the context of the waste collection and disposal service, protected in compliance with anti-Covid-19 regulations.”

In particular, as already represented by the Municipality in the notification of personal data breach sent to the Authority, pursuant to Article 33 of the Regulation, on XX (note prot. n. XX of XX), the aforementioned dissemination – which occurred in the month of XX – consisted of making available “On WhatsApp and then on Facebook [...] of] a photo of the internal document with which the Entity informed the company SATE S.p.a., manager of the waste collection service, of the residences where individuals reside for whom a particular form of collection related to the Covid-19 epidemiological emergency must be activated,” involving a total of nine interested parties.

2. The investigative activity

During the checks carried out to ascertain the representations made in the complaint and in the notification of personal data breach, the Office, with an initial note dated XX (prot. n. XX), invited the Municipality to provide any useful information regarding the above-mentioned incident, pursuant to Article 157 of the Code. The Municipality, with a note dated XX, provided a response to the aforementioned request for information stating that:

- “On XX, the ASL of Viterbo [...] informed the Prefectural Commissioner of the Municipality of Civita Castellana [...] of the positive Covid cases of some citizens of Civita Castellana, for the consequent actions necessary for the adoption of containment measures for the Sars Covid 19 virus, sending a specific list of positive citizens or those in quarantine”;

- “Upon receiving the communication, the Prefectural Commissioner of the Municipality of Civita Castellana, [...] ordered the activation of the anti-Covid-19 procedures provided by the Entity and already in use since the beginning of the pandemic. These procedures involved two internal service communications: the first addressed to the Commander of the Local Police [...] for the activation of home monitoring of individuals affected by the virus, the second addressed to the company S.A.T.E. S.p.a., manager of the integrated waste collection and disposal service, for

the activation of special collection and differentiated disposal services for waste coming from residences with individuals affected by the Sars Covid-19 virus [...];

- "With reference to the case under investigation, on the morning of XX, at the direction of the Prefectural Commissioner of the Municipality of Civita Castellana [...] two distinct communications were sent, as per practice: the first addressed to the Commander of the Local Police [...] containing the complete list transmitted by the ASL of Viterbo, for the activation of home monitoring and for the respective control responsibilities, the second sent via certified email to the company S.A.T.E. S.p.a. containing a minimized list of the information contained (surname and name only with initials, address integral, start and end date of isolation [...]).

Both service communications were sent with the wording "ENSURE MAXIMUM CONFIDENTIALITY AND PROTECTION OF PRIVACY";

- "On XX, the Prefect Commissioner of the Municipality of Civita Castellana [...] was contacted by the ASL of Viterbo, informing him that a photo of the internal document with which the Entity had notified the company S.A.T.E. S.p.a. for the collection of special waste had appeared on WhatsApp and Facebook";

- "On XX, [...] the CEO of S.A.T.E. S.p.a., in addition to the previous communication, reported that on XX he filed a complaint regarding the events that occurred and that he had taken steps to acquire elements aimed at ascertaining both the methods by which the event occurred, as well as any responsible parties for any further and required legal obligations";

- "On XX, the Prefect Commissioner of the Municipality of Civita Castellana [...] sent to the company S.A.T.E. S.p.a. [...] a communication of violation of personal data [...] with which, with reference to what happened, he requested to keep the Municipality of Civita Castellana promptly informed about the outcomes of the ongoing investigation [...]".

Following a further request for information (note prot. n. XX of XX), the Municipality, with note of X, stated, among other things:

- "The Guarantor requests the administration for the contract or other legal act that regulated the relationship with S.A.T.E. S.p.a., based on the erroneous belief of the applicability of Article 28 of the Regulation [...] In fact, in the opinion of the undersigned, this provision is not relevant to the facts under investigation, as the relationships in question can be framed within the different hypothesis of autonomous ownership of the processing and not in that described by the aforementioned Article 28 GDPR, applicable where the processing is carried out by the Processor on behalf of a Controller";

- "S.A.T.E. S.p.a. is a mixed public-private company entrusted with the service of waste collection and disposal. In this context, having examined the type of service entrusted and the purposes of the data processing carried out by the two parties involved, the distinct and autonomous ownership of the processing by the Municipality of Civita Castellana and S.A.T.E. S.p.a. is evident."

Lastly, with note of XX, in response to a further request for information from XX (prot. n. XX), the Municipality also clarified:

- "To the company S.A.T.E. S.p.a., manager of the waste collection service, a minimized list of only the necessary information to identify the residence and the user of the subject to activate the specific collection procedure was transmitted. The initial points served to identify the subject to whom to deliver the kits, the address to identify the collection point, the start and end of the isolation to identify the period in which to carry out the specific COVID collection service. There is no question, as provided for by Article 6 par. 1 lett. e) of Regulation (EU) 2016/679, regarding the lawfulness of the transmission of the personal data in question, necessary for the execution of a task of public interest and connected to public powers such as waste collection; transmission, among other things, provided for by special legislation enacted during the Covid-19 health emergency and in compliance with the provisions

issued by the Higher Institute of Health with Report ISS COVID-19 n. 3/2020. In any case, the communication took place via the institutional PEC of the Entity to the address of the company S.A.T.E. S.p.a. [...] CONFIDENTIAL in which it is specifically stated to ENSURE MAXIMUM CONFIDENTIALITY AND PROTECTION OF PRIVACY";

- "It must be emphasized that the only party responsible for the dissemination of the communication containing the minimized data is to be found in S.A.T.E. S.p.A., since the operators there, after receiving the PEC from the undersigned Entity, contrary to the indications provided ("... ensure maximum confidentiality and protection of privacy..."), proceeded to print the message and post it on the company bulletin board, without taking any action to ensure what was requested by the Entity, namely to ENSURE MAXIMUM CONFIDENTIALITY AND PROTECTION OF PRIVACY. In any case, from information acquired about the incident, the dissemination of the data in question occurred only within a WhatsApp chat and, therefore, among a very limited number of people";

- "Regarding the Guarantor's request for the transmission of the contract or other legal act pursuant to Article 28 of the Regulation, the defensive deductions already submitted regarding the autonomous ownership of the processing are reiterated. [...] In the opinion of the undersigned, the Guarantor's references to the notification of the personal data breach of XX and the alleged contradiction between the notification itself and the Entity's deductions regarding autonomous ownership do not hit the mark. Moreover, the error of assessment made by the Municipality in the communication of the data breach concerning the controller/processor relationships between the municipal administration and the service contractor cannot lead to asserting the Entity's culpability, which must indeed be framed as an autonomous Controller of the processing just like S.A.T.E. S.p.A.";

- "As previously stated, S.A.T.E. S.p.a. is a mixed public-private company entrusted with the service of waste collection and disposal. The relationships between the contracting authority and the company are governed by a contract signed in 2001 and integrated in 2011, that is, prior to the entry into force of the GDPR. The COVID collection service was introduced by a regulation.

****Special provisions dictated during a health emergency****

which have nothing to do with the ordinary waste collection that was carried out even during this period in the usual manner. The treatment carried out by S.A.T.E. S.p.A. to perform the COVID collection service was directly governed by the special regulations in force during the health emergency. The health protocols determined the purposes of that type of personal data processing. With the "Guidelines 07/2020 on the concepts of data controller and data processor pursuant to the GDPR" [...], it was established that the term "determines" included in Article 4, paragraph 7 of the Regulation, means that [...] the data controller is the entity that effectively exercises a decisive influence on the purposes and means of the processing itself [...] and that] "... determining the purposes and means equates to deciding, respectively, the 'why' and the 'how' of the processing: given a specific processing operation, the data controller is the entity that has determined the why of the processing (i.e., 'for what purpose' or 'for what reason' it is carried out) and how that objective is achieved (i.e., what means are employed to achieve it) ..." and furthermore that [...] "... the exchange of the same data or sets of data between two entities in the absence of jointly determined purposes or means of processing should be considered a transmission of data between distinct data controllers ...". In this regard, it is specified that the means ("the how of the processing") employed by the service provider to achieve the objective of collecting COVID waste were autonomously determined by S.A.T.E. S.p.A., which, among other things, was obliged to comply with health protocols and emergency regulations. The above is emphasized solely to support the thesis of the autonomous ownership of personal data processing between the Entity and the company in the overall context of the service assignment for waste collection. And it is precisely in this context that the answers to the documentary requests made by the Authority should be sought. In fact, on one hand, there is no contract or other legal act governing the relations with S.A.T.E. S.p.A. in the records of the Entity, pursuant to Article 28 of the regulation, due to the firm belief in the different, distinct, and autonomous "ownership" of the processing (considering also the type of original service assigned and the purposes of the data processing of the two entities involved) and, on the other hand, in the specific case of the COVID collection service (subject of investigation), it is reasonable to believe that the Municipality of Civita Castellana adopted all appropriate precautions in transmitting the communication via PEC of XX [...];

- "In relation to the present proceeding, the Data Protection Officer was involved immediately after the event, with whom the notification of the personal data breach was shared and subsequently, in relation to the management of the complaint, the current Data Protection Officer, [...] What emerges is that, unlike what happened over two years before and after the event of XX, no other breach occurred in the management of the information sent by the Entity to SATE S.p.A. for the management of the waste collection service in COVID-19 mode";
- "The uniqueness of the event and the extreme limitation of the dissemination of data (which occurred only within a WhatsApp chat and, therefore, among a very limited number of people) are the distinguishing characteristics of what happened, the cause of which must be exclusively attributed to the incorrect protection and management of the information sent by the Entity by SATE S.p.A. and its operators, [...]";
- "In conclusion, it is believed that a careful and comprehensive assessment of what happened [...] cannot fail to arrive at the conclusion that, aside from the formalism of what is provided for in Article 28 of the regulation (if deemed necessary in the examined case), the activity carried out by the Entity was informed by full compliance with the special regulations introduced by the legislator during the management of the pandemic phase to limit the spread of the COVID-19 virus and the provisions introduced by the Higher Institute of Health (ISS COVID-19 Report No. 3/2020) and by the Authority itself (FAQ 7), as well as the regulations on personal data protection and, above all, lawful as it was necessary for the execution of a task of public interest and connected to public powers such as the collection of COVID waste."

For completeness, it is noted that the Company, in response to a request for information from XX by the Office, with a note of XX specified that "The legal relationship between the municipality and the company pursuant to Article 28 consists of a service contract [...]."

With reference to the conduct of the Municipality, the Office, based on the elements acquired and the facts emerged following the investigative activity, notified the same, on XX (prot. no. XX) pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation for having acted:

- in a manner not compliant with the principle of "accountability," in violation of Articles 5, paragraph 2, and 24 of the Regulation, having failed to adopt adequate policies and measures to ensure and be able to demonstrate that the processing of personal data carried out is compliant with the Regulation;
 - in violation of Article 28 of the Regulation, for having acted in the absence of a written agreement suitable to regulate the relations concerning data protection with the Company, the data processor.
- The Municipality, with the aforementioned act, was invited to produce to the Authority defensive writings or documents.

or requested to be heard by the Authority (art. 166, paragraphs 6 and 7, of the Code, as well as art. 18, paragraph 1, of Law No. 689 of November 24, 1981).

In a note dated XX, the Municipality submitted a defense memorandum, stating, in particular, that: "[...] what is preliminarily contested is not how the data was processed, but how it was disseminated. In other words, the fact that the Entity communicated sensitive data to the waste collection service provider is not being censured, nor the methods by which this occurred, but rather that this data was disseminated by the same company in a manner that exceeded the purpose for which it was communicated to them."

"From this, it clearly follows that [...] the party that violated the principle of data confidentiality is not the Municipality, but the company entrusted with the service, SATE S.p.a., and in particular its employees."

"It is indeed a certain and now established fact, following the investigation conducted by this Authority and by the same admission of the company SATE S.p.a., that the reason why the data processing was excessive in relation to the communication is attributable to the fraudulent conduct of the company's personnel who disseminated information that should have remained confidential in a WhatsApp chat and used to carry out the assigned service safely."

"It is also contested that the lack of a contract or legal act with the aforementioned company resulted in the absence of defined instructions (see paragraph 3 of art. 28 cited) aimed at ensuring greater

compliance with the processing of personal data. This is evidenced precisely by the illicit dissemination in question, which, although attributable – based on the ongoing investigation – to the responsibility of the company, was endorsed by the absence of precise and appropriate security and organizational measures capable of ensuring compliance with the regulations on the protection of personal data and fostering greater sensitivity on this issue.”

“Therefore, the second reason for contestation [by the Authority] is that the cause of the excessive dissemination of the communication is to be attributed to the lack of a contract or legal act with the aforementioned company, which resulted in the absence of defined instructions aimed at ensuring greater compliance with the processing of personal data pursuant to paragraph 3 of art. 28 of the Regulation. In this regard, it is noted that in managing the health emergency during the COVID-19 pandemic phase, the Municipality simply acted as an intermediary between the ASL, the holder of the health data, and the company entrusted with the waste collection and disposal service, which was called to carry out the activity safely.”

“The Municipality limited itself exclusively to processing the data sent by the ASL, minimizing it to the strictly necessary to provide the information required by the company entrusted with the waste collection and disposal service for the execution of the COVID collection service, according to the provisions issued by the Istituto Superiore di Sanità with Report ISS COVID-19 No. 3/2020, in order to guarantee and protect the health of the operator assigned from the risk of contagion, balancing it with the confidentiality of personal data.”

“Although the transmission of data between the Entity and the company SATE S.p.a. was carried out without observing the formalities required by art. 28 of the Regulation, having not entered into a written contract or other legal act that bound it as the data processor to the data controller [...] it must be absolutely clarified that the communication took place via the institutional PEC of the Entity to the address of the company S.A.T.E. S.p.a. [...] CONFIDENTIAL in which it is specifically stated to ENSURE MAXIMUM CONFIDENTIALITY AND PROTECTION OF PRIVACY.”

“Therefore, it must be absolutely noted and taken into account that it is not true at all that the Entity, as the data controller, failed to implement adequate technical and organizational measures to ensure that the processing was carried out in accordance with the regulation, violating the principle of accountability referred to in art. 5, paragraph 2, and art. 24 of the Regulation. The only thing that can be noted is that it did not enter into a written contract or another legal act that bound SATE S.p.a. as the data processor to the data controller.”

“This, in the judgment of this Entity, must lead, within the framework of a correct and fair assessment of the facts that occurred and any sanctioning measure, to balance on one hand the necessary and mandatory activity of transmitting data necessary for containing the spread of the COVID-19 virus, which should be considered paramount compared to the failure to comply with the formalism of art. 28 of the Regulation.

“Although what is provided for in art. 28 of the Regulation was not specifically observed, the transmission of data from the Entity to SATE S.p.a. was accompanied by the adoption of measures aimed at protecting confidentiality and privacy [...]. All of this considered, it is absolutely clear that the only party responsible for the excessive dissemination of the communication containing the minimized data is to be found in S.A.T.E. S.p.A., since the operators assigned there, after receiving the PEC from the undersigned Entity, contrary to the instructions provided (“... ensure maximum confidentiality and protection of privacy ...”), proceeded to print the message and post it on the company bulletin board, without taking any action to ensure what was requested by the Entity, namely TO ENSURE MAXIMUM CONFIDENTIALITY AND PROTECTION OF PRIVACY.”

“In light of the above illustrated and argued, it is believed that, even if the Entity may be found responsible for not having promptly...”

observed what is prescribed by Article 28 of the Regulation, it is incontrovertible that suitable measures have been implemented to prevent the dissemination of personal data, and that for this reason, concrete responsibility must be sought exclusively against SATE S.p.a. and its personnel, [...].

During the hearing, requested pursuant to Article 166, paragraph 6, of the Code and held on XX (see

minutes prot. no. XX of XX), the Municipality declared, in particular, that:

“By way of integration of what is already in the records, it is specified that the relationship between the Municipality and the company SATE S.p.a., from the perspective of personal data protection, was not regulated pursuant to Article 28 of the GDPR at the time of the events in question”;

“The communication of data of individuals positive for Covid from the Municipality to SATE S.p.a., the operator of the waste collection service, occurred via reserved certified email, in compliance with data security measures and ensuring maximum confidentiality. The transmission of that data was provided for by a special regulation in force at the time of COVID”;

“The communication was necessary to protect workers and citizens, and the Municipality strictly adhered to the provisions issued by the Higher Institute of Health, among other things, finding itself in an exceptional festive moment (XX)”;

“The procedure had been previously agreed upon with SATE S.p.a. The dissemination was limited to very few people; it involved a photo taken by an operator of SATE S.p.a. of a communication posted on a bulletin board inside the workplace and shared on a private chat”;

The contract with SATE S.p.a. dates back to 2001, and the contractual relationship with the company has recently been redefined [...] The Municipality specifies that the relationship with SATE S.p.a., pursuant to Article 28 of the GDPR, was regulated in XX. [...] the Municipality has sought to hold SATE S.p.a. accountable in terms of confidentiality also through informal meetings.

“What occurred must be contextualized to the first emergency period in which the Municipality was required to comply with emergency regulations and the new obligation to communicate data provided by the ASL to the waste manager”;

“It wishes to represent the utmost sensitivity and attention to the regulations regarding personal data protection. By way of example, it has appointed the DPO, adapted the forms, the website, conducted training meetings with the DPO, and paid attention to the methods of processing personal data even in the provision of various services such as the granting of social and economic contributions.”

****3. Outcome of the investigative activity****

****3.1. The regulations regarding personal data protection.****

The processing of personal data must occur in compliance with the applicable regulations regarding personal data protection and, in particular, the provisions of the Regulation and the Code.

For “personal data” it is understood as “any information relating to an identified or identifiable natural person (‘data subject’)”. Furthermore, “a natural person is considered identifiable who can be identified, directly or indirectly, with particular reference to an identifier such as a name, an identification number, location data, an online identifier, or one or more specific elements of their physical, physiological, genetic, mental, economic, cultural, or social identity” (Article 4, paragraph 1, no. 1, of the Regulation).

Additionally, it is noted that the processing of personal data carried out by public entities is, as a rule, lawful only if necessary “for compliance with a legal obligation to which the data controller is subject” or “for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller” (Article 6, paragraph 1, letters c) and e), of the Regulation). It is also provided that “Member States may maintain [...] more specific provisions to adapt the application of the rules of this regulation regarding processing, in accordance with paragraph 1, letters c) and e), determining more precisely specific requirements for processing and other measures to ensure lawful and fair processing [...]” (Article 6, paragraph 2, of the Regulation).

Processing must also always occur in compliance with the principles regarding personal data protection set out in Article 5 of the Regulation, including the principle of “accountability” (Article 5, paragraph 2 and Article 24 of the Regulation).

Lastly, it is highlighted that, pursuant to Article 28 of the Regulation, the controller may entrust processing to third parties that provide sufficient guarantees regarding the implementation of

appropriate technical and organizational measures to ensure that the processing is in compliance with the regulations regarding personal data protection ("data processors"). In this case, "processing by a processor shall be governed by a contract or other legal act under Union or Member State law, binding the processor to the controller and stipulating the subject matter of the processing and the duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects, the obligations and rights of the data controller." The data processor is, therefore, authorized to process the data of the data subjects "only on documented instructions from the controller" (Article 28, paragraphs 1 and 3, of the Regulation).

****3.2. Lack of regulation of the relationship with the Company and violation of the principle of accountability****

It is useful to preface that the management activity of

Urban waste falls within the institutional activities entrusted to local authorities, who are the data controllers, and can be carried out by third parties – data processors – on behalf of the data controller.

From the assessment carried out based on the elements gathered and the facts emerged during the investigative activity, it was found that the processing of the data in question, carried out by the Company on behalf of the Municipality, was initiated without the role being regulated pursuant to Article 28 of the Regulation (nor pursuant to Article 29 of the Code, in the text prior to the amendments made by Legislative Decree No. 101 of August 10, 2018).

In fact, the service contract signed in 2001 and subsequently integrated in 2011, which initially conferred the functions of managing the "public urban hygiene service," in place at the time of the personal data breach and only subsequently superseded by the new contract of XX, did not meet the characteristics of the legal act aimed at regulating the relationship with the data processor, as it did not contain either the elements provided for by Article 29 of the previous Code or the elements provided for by Article 28 of the Regulation.

In this regard, it should be clarified that, although the processing was initiated by the Municipality in the period prior to the entry into force of the Regulation (the relationship having been adopted since 2001 and subsequently integrated – initially – in 2011), for the purposes of identifying the applicable legislation, from a temporal perspective, it must be noted that, based on the principle of legality set forth in Article 1, paragraph 2, of Law No. 689/1981, "Laws that provide for administrative sanctions apply only in the cases and times considered therein." This implies the necessity to take into account the provisions in force at the time of the committed violation; in the case at hand, given the permanent nature of the contested unlawful act, such moment must be identified at the time of cessation of the unlawful conduct, which occurred in the month of XX with the regulation of the relationship with the Supplier pursuant to Article 28 of the Regulation and, therefore, during the full validity of the provisions of the Regulation and the Code (as amended by Legislative Decree No. 101/2018).

In any case, it is stated that the Municipality has claimed not to have appointed the Company as the data processor, having considered it an autonomous data controller for the personal data underlying the management of urban waste.

In this regard, as represented by the Authority, the Guidelines 07/2020 on the concepts of data controller and data processor under the GDPR, version 2.0, adopted on July 7, 2021, by the European Data Protection Board, provide that "the controller determines the purposes and means of the processing, that is, the reason and the methods of the processing. The data controller is called to decide both on the purposes and on the means. However, certain more practical aspects related to the implementation of the processing ('non-essential means') may be delegated to the data processor. To be qualified as a data controller, it is not necessary for that subject to have actual access to the data processed" (see p. 3).

Furthermore, the aforementioned Guidelines express a general concept according to which "The data controller is the subject who decides on certain key elements of the processing itself. The ownership can be defined by law or can derive from an analysis of the factual elements or the circumstances of the case" (see p. 3).

Highlighting the circumstances that emerged in this specific case, the following observations are made:

- a) in the document concerning the notification of the personal data breach sent to the Authority on XX, the Municipality stated, in section B, that it is the data controller, and indicated, in section B2 (Additional subjects involved in the processing "Indicate the references of additional subjects involved and the role played (co-controller or data processor, representative of the controller not established in the EU)") the Company as the data processor;
- b) in the note of XX (see Annex 7 of the aforementioned note of XX), the Extraordinary Commissioner addresses the Company, asking "pursuant to Article 28 of the Regulation [...] to keep the Municipality of Civita Castellana promptly informed about the outcomes of the ongoing investigation";
- c) the Company did not define itself as an autonomous controller nor did it contest its role as "data processor," attaching the service contract of December 30, 2010. This contract, not containing the elements provided for by Article 28 of the Regulation (see specifically paragraph 3), does not meet the characteristics of the legal act aimed at regulating the relationship between controller and processor, but contains provisions from which it is clearly evident how this Municipality has, in fact, defined both the purposes and the methods of managing the "public urban hygiene service."

It is finally emphasized that "The presence (or absence) of a written agreement, however, is not decisive for the existence of a controller-processor relationship. [...] a controller-processor relationship could exist even in the absence of a written processing agreement. However, this would imply a violation of Article 28, paragraph 3, of the GDPR. Moreover, in certain circumstances, the absence of a clear definition of the relationship between the controller and the data processor may lead to the issue of the lack of a legal basis on which any processing should..."

based, for example, on the communication of data between the data controller and the alleged data processor" (see, note 42 to point 103 of the aforementioned Guidelines).

On the other hand, the obligation to regulate the relationship with subjects acting on behalf of and in the interest of the data controller was already provided for by the previous framework (see, Articles 4, letter g) and 29 of the Code, prior to the amendments made by Legislative Decree No. 101/2018, which provided that "the data controllers enter into written legal acts with the aforementioned processors, specifying the purpose pursued, the type of data, the duration of the processing, the obligations and rights of the data processor, and the methods of processing (paragraph 4-bis).... The processor carries out the processing in accordance with the conditions established under paragraph 4-bis and the instructions given by the controller, who, also through periodic checks, supervises the strict compliance with the provisions of paragraph 2, their own instructions, and what is established in the acts referred to in paragraph 4-bis. (paragraph 5)"; in this regard, see Cass., Section I Civil, judgment No. 21234 of July 23, 2021).

The violation of the aforementioned provisions, even if it did not result in the application of an administrative sanction (unlike what is now provided for by Articles 28 and 83, paragraph 4, of the Regulation), still led to processing that was not compliant with data protection regulations, potentially constituting an unlawful communication of personal data in favor of a subject who, not having been designated as a processor, was a third party with respect to the processing (see Decision No. 312 of July 18, 2023, web doc. 9920578; Decision No. 313 of July 18, 2023, web doc. 9920645; Decision No. 314 of July 18, 2023, web doc. 9920664; Decision No. 163 of April 27, 2023, web doc. 9900808; Decision No. 164 of April 27, 2023, web doc. 9900826; Decision No. 270 of July 21, 2022, web doc. 9811732; Decision No. 162 of April 28, 2022, web doc. 9777974; Decision No. 292 of July 22, 2021, web doc. 9698558; Decision No. 293 of July 22, 2021, web doc. 9698597; Decision No. 294 of July 22, 2021, web doc. 9698724; Decision No. 351 of September 29, 2021, web doc. 9716256; Decision No. 294 of July 22, 2021, web doc. 9698724; Decision No. 49 of February 11, 2021, web doc. 9562852; Decision No. 81 of March 7, 2019, web doc. 9121890).

The failure to define the relationship with the Company under Article 28 of the Regulation (formerly Article 29 of the Code prior to the amendments made by Legislative Decree No. 101/2018) has also resulted in a violation of the accountability principle set forth in Articles 5, paragraph 2 and 24 of the Regulation, as clarified in the aforementioned Guidelines, this principle - from the perspective of trust

and legitimate expectation that data subjects place in the data controller - imposes on the latter the obligation to ensure and be able to demonstrate that “the processing is carried out in accordance with the Regulation” also in terms of defining the roles played by the various parties involved in a personal data processing activity and the consequent allocation of responsibilities.

From the perspective of adopting the necessary technical and organizational security measures to ensure compliance with the personal data processing carried out, it is noted that, although the Regulation also imposes specific obligations in this regard on the data processor (Article 32 of the Regulation), it remains clear that the data controller is the subject on whom a “general responsibility” falls (see Article 5, paragraph 2 and Article 24 of the Regulation), even when these are carried out by other subjects “on its behalf” (recital 81, Articles 4, point 8) and 28 of the Regulation).

In fact, pursuant to the aforementioned Article 28 of the Regulation, the data controller may entrust the processing of personal data to third parties that provide sufficient guarantees regarding the implementation of appropriate technical and organizational measures to ensure that the processing is compliant with the data protection regulations, regulating the processing by the relevant data processor through a contract or other legal act under Union law or the laws of the Member States, which binds the processor to the controller and thus legitimizes the former to process the data of the data subjects “only on documented instructions from the controller” (Article 28, paragraphs 1 and 3, of the Regulation; in this regard, see, among others, Cass., Section I Civil, judgment No. 21234 of July 23, 2021).

The failure to enter into a contract or legal act with the Company has therefore resulted in the absence of defined instructions (see paragraph 3 of the aforementioned Article 28) aimed at ensuring greater compliance with the processing of personal data. This is evidenced precisely by the illicit dissemination in question, which, although attributable - based on the investigation carried out - to the responsibility of the Company, has been endorsed precisely by the absence of precise and adequate technical and organizational security measures capable of ensuring compliance with the data protection regulations and raising greater awareness on this issue, also in terms of attention from the internal personnel of the Company to the risks arising from unauthorized or unlawful processing.

All of the above having been stated, it is established that - without prejudice to the assessments regarding the lawfulness of the processing carried out by the Company, which is the subject of a separate proceeding - the Municipality, until the month of XX, operated in violation of Article 28 of the Regulation by not having regulated the relationship with the Supplier from the perspective of data protection and in a manner not compliant with the principle of “accountability” set forth in Articles 5, paragraph 2 and 24 of the Regulation.

4. Conclusions.

of the applicable regulations, appropriate and proportionate to the circumstances of the case.

6. Conclusion

In light of the above considerations, the Authority confirms the findings regarding the unlawful processing of personal data by the Municipality, which has occurred in violation of Articles 5, paragraph 2, 24, and 28 of the Regulation. The total amount of the administrative fine is set at €3,000.00 (three thousand/00) for the violations identified. The Municipality is required to comply with this decision and take necessary measures to ensure future compliance with data protection regulations.

7. Notification

This decision will be communicated to the Municipality and published on the Authority's website in accordance with Article 166, paragraph 7 of the Code.

8. Right to Appeal

The Municipality has the right to appeal this decision before the competent judicial authority within the terms established by law.

9. Final Provisions

This decision is effective immediately and must be complied with within the timeframe specified herein.

Date: [Insert Date]

Authority: [Insert Authority Name]

of Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

Considering the particular nature of the personal data subject to dissemination by the (de facto) data controller, it is also deemed necessary to apply the accessory sanction of publication of this provision on the Garante's website, as provided for by Article 166, paragraph 7 of the Code and Article 16 of the Garante Regulation No. 1/2019.

It is finally noted that the conditions of Article 17 of Regulation No. 1/2019 are met.

ALL OF THE ABOVE CONSIDERED, THE GARANTE

declares, pursuant to Article 57, paragraph 1, letter f), of the Regulation, the unlawfulness of the processing carried out by the Municipality of Civita Castellana for the violation of Articles 5, paragraph 2, 24, and 28 of the Regulation, as detailed in the reasoning;

ORDERS

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, the Municipality of Civita Castellana, with legal headquarters at Piazza Matteotti No. 3 - 01033 Civita Castellana (VT), Tax Code 00065540569, to pay the total amount of €3,000.00 (three thousand/00) as an administrative pecuniary sanction for the violations indicated in the reasoning. It is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction;

ORDERS

the Municipality of Civita Castellana to pay the total amount of €3,000.00 (three thousand/00) in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, according to the methods indicated in the attachment, within thirty days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law No. 689/1981;

DISPOSES

the publication of this provision on the Garante's website pursuant to Article 166, paragraph 7, of the Code (see Article 16 of the Garante Regulation No. 1/2019);

the annotation of this provision in the internal register of the Authority, as provided for by Article 57, paragraph 1, letter u), of the Regulation, of the violations and measures adopted in accordance with Article 58, paragraph 2, of the Regulation (see Article 17 of the Garante Regulation No. 1/2019).

Pursuant to Articles 78 of the Regulation, 152 of the Code, and 10 of Legislative Decree No. 150/2011, it is possible to appeal this provision before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, February 22, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Cerrina Feroni

THE SECRETARY GENERAL

Mattei